

Dix incidents, une question simple

Dans chaque incident, qu'est-ce qui a lâché en premier ?

Kélian Kaddouri

Ce qu'on vous demande. Vous allez lire dix récits d'incidents réels, tirés de rapports d'enquête publics. Pour chacun, on vous demande simplement, entre deux domaines qui ont tous les deux flanché, **lequel a flanché en premier et a entraîné l'autre**. C'est tout. Comptez une heure. Aucune connaissance technique n'est nécessaire : les faits vous sont donnés, vous n'avez qu'à les ordonner.

Les cinq domaines

Toute la grille porte sur ces cinq domaines. Retenez les noms, ils suffisent.

Gouvernance	Qui décide, qui est responsable de quoi, quelle importance la direction accorde à la sécurité, quels moyens elle y met.
Incidents	Repérer qu'un incident a lieu, l'escalader, y répondre, en informer les clients et les autorités.
Tests	Tester avant de mettre en service, vérifier régulièrement, appliquer les correctifs, renouveler les certificats et les clés.
Prestataires	Les fournisseurs et sous-traitants, et la dépendance à un outil ou un service extérieur.
Partage d'infos	Recevoir et faire circuler les alertes sur les menaces, en interne comme avec l'extérieur.

Comment répondre

Pour chaque case, vous avez le nom de deux domaines. Écrivez l'une de ces quatre réponses :

le nom d'un domaine	si le récit montre que celui-là a lâché en premier <i>et</i> a entraîné l'autre. Écrivez simplement son nom, par exemple <i>Gouvernance</i> .
en même temps	les deux ont lâché, mais rien ne dit lequel a entraîné l'autre.
non concerné	au moins un des deux domaines n'apparaît pas dans ce récit.
je ne sais pas	vous hésitez, ou le récit ne permet pas de trancher.

La règle à tenir, et la seule. N'écrivez le nom d'un domaine que si le récit **montre** qu'il a entraîné l'autre. Si les deux problèmes sont juste racontés l'un à côté de l'autre, répondez *en même temps*. Dans le doute, *je ne sais pas* est une bonne réponse. Il n'y a pas de réponse attendue, et si vous répondez souvent *en même temps* ce n'est pas un problème : c'est même une information.

Les sept récits

1. Fournisseur de messagerie d'entreprise, 2023

Rapport d'une commission d'enquête publique américaine.

- Le rapport juge que l'entreprise ne mettait pas assez la sécurité au premier plan, et recommande que la direction générale et le conseil s'en saisissent eux-mêmes.
- Le renouvellement des clés de sécurité, fait à la main et rarement, a été arrêté en 2021 après une panne, sans être remplacé par un système automatique.
- Aucune alerte ne signalait qu'une clé devenait trop ancienne.
- Une clé créée en 2016, censée ne plus servir, a été utilisée par les attaquants.
- L'entreprise n'a pas découvert l'attaque elle-même : c'est un client qui l'a prévenue.
- Ses communications publiques donnaient une explication de l'origine de la fuite ; elles ont été corrigées six mois plus tard pour dire que l'origine restait inconnue.
- Le rapport relève des failles dans la façon dont l'entreprise sécurise les sociétés qu'elle rachète : les accès d'un ingénieur venu d'une société rachetée ont servi à entrer.

2. Banque britannique, migration informatique de 2018

Enquête indépendante commandée par la banque ; sanctions des deux autorités de contrôle britanniques ; sanction personnelle de l'ancien directeur informatique.

- Cinq millions de clients ont été basculés sur une nouvelle plateforme. Beaucoup se sont retrouvés sans accès à leur compte, certains ont vu des montants disparaître, d'autres ont eu accès aux comptes d'autres clients.
- Les autorités ont sanctionné des manquements dans le pilotage du projet et dans la surveillance des sous-traitants.
- Le chantier a mobilisé plus de 70 fournisseurs et plus de 1 400 personnes ; l'enquête juge la surveillance de ces fournisseurs insuffisante.
- Deux centres de données n'ont pas été testés avant la mise en service, l'un étant réservé à l'exploitation : l'ensemble n'a donc jamais été testé en charge réelle.
- Sur 5 359 défauts recensés, 4 424 étaient encore ouverts le jour du démarrage.
- L'ancien directeur informatique a été sanctionné à titre personnel pour n'avoir pas veillé à ce que la banque encadre convenablement son contrat de sous-traitance.
- La gestion de la crise et l'information des clients ont été critiquées ; le coût dépasse 300 millions de livres.

3. Société américaine de renseignement financier, 2017

Rapports d'un organisme d'audit public et d'une commission parlementaire.

- En mars 2017, une alerte publique demande de corriger sans délai un logiciel très répandu. L'entreprise diffuse l'alerte en interne, mais la liste de diffusion n'était plus à jour et les personnes concernées ne l'ont jamais reçue.
- Un contrôle automatique passé la semaine suivante n'a pas repéré la faille.
- Un certificat de surveillance avait expiré en janvier 2017 : sans lui, les outils de surveillance ne voyaient plus rien. Personne ne s'en est aperçu pendant plus de six mois. Plus de 300 certificats étaient expirés, dont 79 sur des systèmes critiques.
- Le certificat a été renouvelé fin juillet 2017 : les outils ont immédiatement signalé une activité suspecte. Les intrus étaient là depuis environ 76 jours.

- L’audit relève qu’il n’y avait pas de responsabilités claires ni de ligne hiérarchique nette dans l’organisation informatique, et un écart entre les règles écrites et leur application réelle, qui a aussi freiné d’autres chantiers de sécurité.
- L’annonce publique a eu lieu en septembre 2017.

4. Société de courtage américaine, 1^{er} août 2012

Décision du régulateur boursier américain.

- Une mise à jour logicielle n’a pas été installée correctement sur tous les serveurs ; l’un d’eux a continué à faire tourner un ancien programme resté actif.
- Le régulateur constate l’absence de contrôles et de procédures convenables pour installer et vérifier ces mises à jour.
- Il constate aussi l’absence de procédures écrites suffisantes pour guider les employés quand un incident technique grave survient.
- L’épisode a duré environ 45 minutes et coûté de l’ordre de 440 millions de dollars.

5. Banque américaine, 2019

Décisions de deux autorités de contrôle bancaires américaines.

- L’autorité sanctionne l’absence d’une véritable évaluation des risques *avant* de basculer des activités importantes chez un hébergeur extérieur.
- Elle relève aussi que les insuffisances constatées n’ont pas été corrigées dans un délai raisonnable.
- Un équipement de protection mal configuré a permis d’accéder aux données hébergées.
- La banque a appris l’intrusion par un signalement venu de l’extérieur.
- La seconde décision porte sur le pilotage et la surveillance par le conseil d’administration.

6. Éditeur de logiciels pour les marchés financiers, janvier 2023

Communications de l’entreprise et réactions des autorités européennes et britanniques.

- Un rançongiciel a frappé une division de cet éditeur, dont les logiciels sont utilisés par de nombreux acteurs des marchés.
- Beaucoup de ses clients ont dû revenir à des traitements manuels.
- Des déclarations réglementaires ont été retardées dans tout le secteur.

7. Logiciel de transfert de fichiers, mai-juin 2023

Listes de victimes publiques.

- Une faille d’un logiciel de transfert de fichiers vendu par un éditeur extérieur a été exploitée massivement.
- Des centaines d’organisations, dont des banques et des assureurs, ont été touchées en même temps et ont dû gérer puis déclarer un incident.

8. Éditeur d’un logiciel de sécurité pour postes de travail, juillet 2024

Analyse technique publiée par l’entreprise elle-même.

- Une mise à jour de contenu diffusée automatiquement contenait un fichier dont le nombre de champs ne correspondait pas au modèle attendu : vingt-et-un champs prévus, vingt fournis.
- Le contrôle automatique chargé de valider ces fichiers avant diffusion ne l’a pas arrêté.

- Les couches de test ne l’ont pas vu non plus, à cause d’un mécanisme de correspondance générique introduit plusieurs mois plus tôt.
- Environ huit millions et demi de machines se sont arrêtées, dans des hôpitaux, des banques, des aéroports et des administrations.
- L’entreprise a dû gérer une crise mondiale et publier une procédure de réparation manuelle, machine par machine.

9. Bibliothèque logicielle libre très répandue, fin 2021

Rapport d’une commission d’enquête publique américaine.

- Une faille critique est révélée dans un composant logiciel gratuit, utilisé sans le savoir par une très grande partie des organisations.
- Beaucoup d’entre elles n’ont pas pu dire où ce composant était installé chez elles : elles ne tenaient pas d’inventaire de ce qu’elles utilisaient et n’avaient pas de règles sur la façon de suivre les composants venus de l’extérieur.
- Les équipes ont donc dû chercher pendant des semaines avant de pouvoir corriger.
- La commission qualifie la faille de durablement présente et estime qu’on la retrouvera pendant une décennie.

10. Petite banque britannique, 2015

Sanctions conjointes des deux autorités de contrôle britanniques.

- Les autorités relèvent que les systèmes et les contrôles de la banque étaient insuffisants pour surveiller et encadrer ses contrats d’externalisation.
- Elles notent qu’il s’agit d’un manquement déjà signalé auparavant et resté sans correction.
- Une panne chez le prestataire qui traitait les paiements par carte a interrompu le service aux clients pendant plusieurs heures.
- Le rétablissement et l’information des clients ont été jugés tardifs.

La grille

Une ligne par incident. Dans chaque case, écrivez le nom du domaine qui a lâché en premier, ou *en même temps*, ou *non concerné*, ou *je ne sais pas*.

Incident	Gouv. / Incid.	Gouv. / Tests	Gouv. / Prest.	Gouv. / Partage	Incid. / Tests	Incid. / Prest.	Incid. / Partage	Tests / Prest.	Tests / Partage	Prest. / Partage
1. Messagerie										
2. Banque UK										
3. Renseign.										
4. Courtage										
5. Banque US										
6. Éditeur										
7. Transfert										
8. Sécurité										
9. Composant										
10. Cartes										

Une dernière question, la plus utile. Y a-t-il une case où vous avez vraiment hésité, ou un enchaînement que vous avez vu sur le terrain et qui ne ressemble à aucun de ces sept récits ?

Pourquoi on vous le demande. J'ai déjà rempli cette grille de mon côté. Je ne vous montre pas mes réponses avant que vous ayez rendu les vôtres, pour ne pas vous influencer : l'intérêt est justement de savoir si deux personnes lisant les mêmes faits y voient le même enchaînement. Un désaccord entre nous n'est pas un échec, c'est le résultat le plus instructif que cet exercice puisse produire.

Merci. Kélian Kaddouri • kkaddouri@nexialog.com